

Beyond Detection

*Architecting Zero Trust Defenses Against AI-Enabled Cyber Threats
in the Indian Enterprise Ecosystem*

**A Research Synthesis on Threat Intelligence, Regulatory Gaps, and Defensive
Architecture**

Aishika Sinha

Master of Laws , Cotton College

Prince Tigga

Electronics and Communication Engineering, Tezpur University

September 2026

Abstract

The democratization of generative artificial intelligence between 2025 and 2026 has expanded the enterprise attack surface beyond the network perimeter into the statistical weights, inference pipelines, and biometric trust models that modern organizations now depend on. India sits at the epicentre of this shift: rapid digitization, mass financial inclusion, and the growth of digital public infrastructure make Indian enterprises and citizens especially lucrative targets.

This paper synthesizes two strands of analysis into a single account. The first is empirical and jurisdictional: it maps the concrete threat matrix confronting Indian enterprises — deepfake executive fraud, the nationwide “digital arrest” extortion epidemic, synthetic-identity injection attacks against Video-KYC, autonomous spear-phishing agents, and AI-enabled market manipulation — and examines the loopholes in the Information Technology Act 2000, the Digital Personal Data Protection Act 2023, and emerging SEBI and RBI mandates that leave enterprises exposed. The second is architectural: it evaluates the global two-layer defense of detection and provenance, the persistent gap between AI governance principles and practice, and the human cognitive limits that undermine both.

Drawing on Zero Trust Architecture as a unifying paradigm, the paper proposes an adapted Trusted Digital Exchange framework — combining a Zero Trust foundation, a provenance-and-detection verification engine, an explainable dynamic trust score, and a continuous governance process — as a practical blueprint for Indian enterprises to build resilience in an environment where authenticity itself can no longer be assumed.

Table of Contents

Abstract

1. Introduction4

2. The Enterprise Artificial Intelligence Adoption Landscape4

3. The Crisis of Trust: Synthetic Media as a Systemic Risk5

4. The AI-Enabled Threat Matrix Targeting Indian Enterprises6

5. The Regulatory Vacuum in Indian Cyber Law8

6. The Two-Layer Defense: Detection and Provenance9

7. The AI Governance Gap: From Principles to Practice10

8. The Human Factor: Cognitive Offloading and Media Literacy11

9. Zero Trust as the Unifying Paradigm12

10. A Proposed Synthesis: The Trusted Digital Exchange Framework13

11. Strategic Conclusions and Recommendations14

References16

1. Introduction

Approximately 88% of organizations worldwide now use artificial intelligence in at least one core business function, a figure driven by the rapid maturation of generative models and enterprise automation between 2025 and 2026 [1].

As automated decision engines, generative copilots, and algorithmic predictors are woven into operational workflows, malicious actors have weaponized the same underlying architectures. The result is an asymmetric threat environment characterized by autonomous agentic exploitation, hyper-realistic synthetic media impersonation, and software injection attacks engineered to defeat identity verification protocols that enterprises have relied on for a decade.

The Indian enterprise ecosystem sits at the centre of this shift. Rapid digitization, the integration of hundreds of millions of new users into the formal banking system, and the expansion of India's digital public infrastructure have made Indian financial institutions, IT services firms, and listed companies exceptionally attractive targets for transnational cybercrime syndicates. The traditional model of human-operated, script-based cybercrime is being replaced by autonomous, scalable, and psychologically tailored algorithmic attacks — from deepfake business email compromise extracting millions from corporate treasuries to the systemic “digital arrest” epidemic targeting the wider population. This paper brings together two complementary lines of analysis. The first is grounded in the concrete threat matrix and regulatory environment specific to India. The second addresses the broader, global conversation about how synthetic media, algorithmic governance, and human cognition interact — and what a durable technical and institutional response looks like. Read together, they motivate a single practical conclusion: neither a purely legal fix nor a purely technical one is sufficient. What Indian enterprises need is a Zero Trust–anchored architecture that treats detection and provenance as inputs to continuous verification, closes the gap between governance principles and daily practice, and accounts for the real limits of human judgment. Section 2 establishes the scale of enterprise AI adoption; Section 3 frames the broader crisis of trust created by synthetic media; Section 4 details the Indian threat matrix; Section 5 examines the regulatory vacuum; Sections 6–9 review the global defense literature on detection, provenance, governance, and human factors; and Sections 10–11 synthesize this into a proposed framework and set of recommendations for Indian enterprises.

2. The Enterprise Artificial Intelligence Adoption Landscape

Enterprise AI adoption is neither uniform across sectors nor monolithic within a given organization. Technology and software-as-a-service firms lead adoption because rapid deployment cycles allow seamless integration of code generation and automated development tooling. Financial services follow closely, driven by the volume of data processed daily and the measurable returns from algorithmic trading, fraud detection, and credit risk scoring. Sectors rooted in physical, legacy operations — manufacturing and agriculture in particular — show markedly slower integration, with control still tethered to deterministic systems even as predictive maintenance gains ground [1].

Sector	AI Adoption Rate	Primary Use Cases	AI vs. Traditional Workflow
Technology & Software	92%	Code generation, automated IT support, product development	78% AI / 22% Traditional
Financial Services & Banking	84%	Fraud detection, algorithmic trading, credit risk scoring	65% AI / 35% Traditional
Media, Marketing & Telecom	78%	Generative content, ad targeting, audience analytics	70% AI / 30% Traditional
E-Commerce & Retail	76%	Recommendation engines, dynamic pricing, forecasting	60% AI / 40% Traditional
Healthcare & Pharmaceuticals	67%	Imaging diagnostics, drug discovery, clinical decision support	52% AI / 48% Traditional
Education & Research	68%	Automated grading assistance, adaptive learning	38% AI / 62% Traditional
Manufacturing & Industrial	52%	Predictive maintenance, visual quality control	45% AI / 55% Traditional
Agriculture	28%	Yield forecasting, autonomous machinery, soil analytics	Not standardized

Within organizations, functional adoption is concentrated: marketing and sales report 72–84% adoption, largely for content generation and hyper-personalized targeting; IT and cybersecurity functions report roughly 65% adoption for automated threat detection and log analysis; operations and customer service report around 60% adoption via chatbots and workflow routing; while core research and development lags at 25–33% [1]. The critical second-order implication is that as AI-driven workloads overtake traditional methods in technology and finance, reliance on human oversight inherently diminishes. When automated systems govern credit approvals, autonomous chatbots handle sensitive client data, and copilots generate proprietary code, the attack surface expands beyond the network perimeter and employee endpoint to encompass the model weights, training corpora, and inference APIs themselves — the foundation on which the threats described in Section 4 are built.

3. The Crisis of Trust: Synthetic Media as a Systemic Risk

Generative models trained on vast datasets can now swap faces, clone voices, and construct entire scenes that never occurred, and deepfake-driven fraud attempts have surged by an estimated 2,137% over three years [30]. The threat is not confined to entertainment or simple impersonation: it extends to targeted cyberattacks, disinformation campaigns, and harassment, and UNESCO has termed the resulting erosion of trust in information itself “the crisis of knowing” [25].

As synthetic media becomes harder to distinguish from genuine content, the ability to authenticate evidence and verify sources becomes increasingly untenable — a problem compounded by the weaponization of plausible deniability: even when a detection tool correctly flags manipulated media, an adversary can dismiss the tool itself as biased or flawed, neutralizing the evidentiary value of the finding.

Threat Category	Description	Representative Examples
Financial & identity fraud	Synthetic media used to impersonate individuals for financial gain or identity theft	Deepfake voice cloning for CEO fraud; AI-manipulated KYC documents
Disinformation & influence operations	Fake content spread to manipulate opinion, disrupt markets, or damage reputations	Fabricated video of public figures; targeted AI-generated narratives
Non-consensual manipulation	Manipulated media distributed without consent	Deepfake harassment campaigns
Cybersecurity attacks	Synthetic media used to bypass security protocols	Impersonating personnel on video calls; defeating facial recognition
Agentic AI misalignment	Autonomous agents acting harmfully due to misalignment or manipulation	Agents exploiting vulnerabilities or acting on corrupted data

The threat is also evolving beyond static, post-production manipulation toward autonomous, “agentic” applications capable of reasoning, planning, and executing tasks with minimal human supervision. An attacker can manipulate such an agent at its interaction surface — the point where it gathers information from its environment — causing it to act against its intended purpose, and researchers have identified risks including data leakage and collusion among cooperating agents [28].

This shift, from managing a static tool to managing an autonomous actor, is the throughline connecting the India-specific threats examined next to the global governance and architecture discussion in Sections 6–9.

4. The AI-Enabled Threat Matrix Targeting Indian Enterprises

4.1 Deepfake Business Email Compromise and Executive Impersonation

The most financially damaging vector currently facing Indian conglomerates is the evolution of business email compromise into real-time deepfake executive fraud. Where classic BEC relied on spoofed addresses and written manipulation, the modern variant bypasses text analysis entirely: attackers harvest high-fidelity audio and video of executives from earnings calls, media interviews, and corporate social

profiles, then use generative adversarial networks and diffusion models to synthesize interactive clones capable of matching an executive's real office or remote setting in real time. Fraudsters then initiate urgent, unscheduled video calls with finance staff, simulate a confidential crisis such as an acquisition or regulatory emergency, and demand an off-book wire transfer to an offshore account. Following the widely reported \$25 million deepfake fraud against the engineering firm Arup in Hong Kong, Indian conglomerates saw a reported 300% spike in attempted deepfake BEC attacks through 2025, prompting HDFC Bank, ICICI Bank, and Kotak Mahindra Bank to issue formal alerts warning staff and retail clients about executive and colleague voice cloning [7].

4.2 The “Digital Arrest” Epidemic and Voice Cloning Extortion

While deepfake video primarily targets corporate treasuries, accessible voice-cloning tools have fuelled a nationwide extortion epidemic known as “digital arrest.” The Indian Cybercrime Coordination Centre (I4C), under the Ministry of Home Affairs, reported that citizens lost roughly ₹120.30 crore to digital arrest scams in the first quarter of 2024 alone [6], and National Human Rights Commission data indicates cumulative losses to cyber-enabled fraud of nearly ₹52,976 crore over six years, of which digital arrest accounts for roughly 8% [4]. In this scheme, scammers pose as officials from the CBI, the Enforcement Directorate, Customs, or the RBI, and falsely accuse the target of crimes such as money laundering or narcotics trafficking linked to a fabricated parcel [2][3]. Generative AI elevates this from a phone scam to sustained psychological trauma. Open-source voice-cloning tools now require as little as three to thirty seconds of audio — harvested from a family member's social media reel or podcast appearance — to synthesize a hyper-realistic, distressed plea for help. Documented cases include a retired engineer in Mumbai who received a cloned call of his son claiming arrest in Bangkok, and a mother in Delhi who received a fabricated audio feed of her daughter in a staged hospital emergency [5]. Attackers combine cloned voices with spoofed international numbers, doctored arrest warrants, and video calls staged in replica police stations to coerce victims into extended “digital custody,” isolating them from family and legal counsel until funds are transferred to mule accounts that are rapidly layered through cryptocurrency mixers. In response, the government has blocked more than 1,700 Skype identifiers and 59,000 WhatsApp accounts linked to these syndicates, and CERT-In has issued advisories (CIAD-2024-0084 and CIAD-2024-0091) urging families to establish verbal “safe words” and to use the 1930 National Cyber Crime Reporting Portal within the “golden hour” of a breach to maximize the chance of freezing recipient accounts [5].

4.3 Synthetic Identity Fraud and Video-KYC Injection Attacks

The RBI's Video Customer Identification Process (V-CIP) mandate depends on biometric trust models that generative AI has substantially undermined. The I4C has warned banks, NBFCs, and fintechs that criminals are deploying synthetic identities to bypass facial authentication and liveness verification [1]. The critical distinction is between presentation attacks — a fraudster holding a printed photo or a screen in front of a real camera, which liveness systems have grown reasonably adept at catching — and injection attacks, which use virtual camera drivers, mobile emulators, or tampered SDKs to feed a synthetically generated video stream directly into the application's capture pipeline, bypassing the physical camera and therefore leaving no physical artifact for a detector to find [8][9]. Even active liveness prompts (blink, turn your head, read this number) can be defeated when the injected stream is itself a real-time deepfake responding on command.

Industry benchmarking shows a roughly nine-fold year-over-year increase in injection attacks, now representing about 16% of identity verification fraud attempts, and one financial institution logged 8,065 biometric injection attempts against its digital loan onboarding system over eight months in 2025 [9]. Compounding the problem, studies indicate that human reviewers correctly identify sophisticated deepfakes during video-KYC calls only about 0.1% of the time — underscoring why manual review cannot be the primary control.

4.4 Autonomous Threat Actors: Agentic Language Models and Spear-Phishing

India's largest IT services providers handle sensitive intellectual property for global clients, making them prime targets for autonomous, agentic attack tooling [10]. Unlike template-based phishing, an autonomous agent can ingest unstructured data about a target's internal jargon, hierarchy, and recent announcements, then generate thousands of hyper-personalized spear-phishing messages that mimic the tone of an internal project manager or client. Once initial access is gained, such agents do not rely on hardcoded command-and-control logic: they can autonomously map network topology, discover vulnerabilities, and generate exploit code on the fly, adapting tactics to the defenses they encounter and exfiltrating source code or client data before a security operations centre can triage the alert [10][11].

4.5 Market Manipulation and AI-Washing

Beyond direct intrusion, generative text and audio models are used to fabricate credible fake press releases, forged regulatory notices, or deepfake audio of executives making damaging statements, targeting companies listed on the BSE and NSE; the resulting volatility can be exploited by attackers pre-positioned in leveraged derivatives before a factual clarification is issued. The inverse phenomenon, “AI-washing” — marketing traditional, human-driven processes as proprietary AI — has produced its own governance scandals; Builder.ai, a startup with significant India-based development operations, faced fraud allegations after investigations found its supposedly AI-driven platform relied heavily on manual labour, illustrating how misrepresentation of AI capability itself has become a distinct category of corporate risk.

5. The Regulatory Vacuum in Indian Cyber Law

5.1 Mens Rea and Plausible Deniability in Agentic Crime

Indian criminal jurisprudence, under the Information Technology Act and the Bharatiya Nyaya Sanhita, requires proving mens rea — criminal intent — typically established by tracing digital footprints back to a human operator. Uncensored, offline open-weight models running entirely on local hardware leave no centralized API logs, so when an operator issues an ambiguous prompt such as “analyze the network for weaknesses” and the agent autonomously exploits a discovered vulnerability, the operator can plausibly claim they authorized only a legal scan. Without a log to prove exact intent, forensic attribution becomes extremely difficult, and the problem is compounded where a syndicate legally downloads a dual-use model in a jurisdiction without a cyber-extradition treaty with India before stripping its safety guardrails. A related liability gap concerns AI coding assistants: when generated code contains a backdoor or a privacy-violating architecture, current

statutes — including BNS §318 (cheating) and IT Act §66D (cheating by personation) — struggle to assign liability between developer and model provider, effectively allowing the legal burden to fall on individual developers and end-user enterprises.

5.2 The DPDP Act 2023: Algorithmic Accountability and Consent

The Digital Personal Data Protection Act, 2023 mandates that personal data processing be tethered to consent or a specific legitimate use, and its Section 2(x) defines “processing” broadly enough to capture AI model training, inference, and automated decision-making [18]. Unlike the EU’s GDPR, which grants a right not to be subject to decisions based solely on automated processing under Article 22, the DPDP Act is silent on algorithmic profiling and does not create an explicit “right to explanation” — a significant gap in high-stakes sectors such as healthcare and finance [18].

Legal analysis suggests algorithmic transparency is nonetheless implied through the combination of existing provisions: Section 4(1) restricts processing to lawful, consented purposes; Section 6(1) requires that consent be genuinely informed — meaning data principals must be told if AI will process their data for, say, automated credit scoring; Section 11 grants a right to a processing summary; and Section 12 guarantees correction and erasure [19][20]. This means an individual denied a loan by an automated system implicitly has the right to know AI was involved, to see the rationale, and to demand correction of inaccurate training data. For enterprises, using previously collected personal data to train new models without separate, specific consent is a clear violation, while Section 3(c)(ii)’s exemption for publicly available data creates ambiguity that some corporations may seek to exploit for scraping training corpora. Penalties for failing to secure personal data — including data exfiltrated by adversarial AI — can reach ₹250 crore per contravention, and Section 9 imposes strict protections for children, banning behavioural monitoring and targeted advertising and forcing structural change in AI-driven ad-tech and ed-tech pipelines [20].

5.3 Sectoral Responses: SEBI and RBI

Recognizing the limits of a broad, principles-based statute, Indian sectoral regulators have moved toward targeted mandates. SEBI issued a formal advisory on May 5, 2026 warning regulated entities — including exchanges and clearing corporations — of the risks generative algorithms pose to data confidentiality and market integrity, and constituted a “cyber-suraksha.ai” task force to coordinate mitigation and threat-intelligence sharing [12][13]. This builds on a December 2024 consultation paper proposing that regulated entities bear sole responsibility for the privacy, security, and integrity of investor data regardless of whether an AI tool is built in-house or procured from a vendor — directly targeting the algorithmic-complicity loophole described above [14].

SEBI has also moved to regulate AI in retail advisory: Registered Investment Advisers and Research Analysts must now disclose, with specificity rather than boilerplate language, what functions AI performs in the advisory process and what human oversight exists, and cannot use algorithmic error as a shield against fiduciary liability [15][16]. SEBI is simultaneously expanding its own AI surveillance capacity to cross-reference listed-company disclosures against external data and detect AI-washing and financial misstatement [17]. The Reserve Bank of India, for its part, has moved to mandate multi-modal biometric liveness detection and stricter capture-environment controls for corporate KYC, directly targeting the injection-attack vector described in Section 4.3.

6. The Two-Layer Defense: Detection and Provenance

In response to synthetic media, the security community has converged on a two-layer defensive strategy: post-hoc detection and pre-emptive provenance. Neither, on current evidence, is sufficient alone.

6.1 Detection Technologies and Their Limits

Detection tools such as Reality Defender apply machine learning to analyze audio, video, images, and text for pixel inconsistencies, unnatural colour fading, or acoustic irregularities imperceptible to humans, producing a confidence score rather than a definitive verdict [24].

The core limitation is fragility under real-world conditions: studies show these tools lose nearly half their accuracy once deployed outside controlled test sets, as attackers adapt to evade known signatures, and adversarial attacks are specifically engineered to fool the underlying models. Framing the problem as a binary “real versus fake” classification also oversimplifies a risk that is inherently probabilistic.

6.2 Provenance Technologies and Their Limits

Provenance takes the opposite approach: embedding a verifiable, cryptographically signed “Content Credential” into media at the point of creation, as specified by the Coalition for Content Provenance and Authenticity (C2PA) [21][23]. Invisible watermarking, such as Google’s SynthID, serves a similar purpose and is generally more robust to compression and re-encoding than metadata alone. The persistent weakness is durability: social media platforms routinely strip embedded metadata — including C2PA manifests — during upload and transcoding, often for privacy or format-standardization reasons rather than malice, so a valid credential at creation may be entirely absent by the time content reaches an end user [22]. Watermarks fare somewhat better but are not invulnerable; benchmarks such as WAVES demonstrate that sophisticated adversaries can remove or alter a watermark while preserving the underlying content’s utility.

Feature	Detection	Provenance (C2PA / Watermarking)
Core mechanism	Post-hoc statistical/perceptual analysis of a media file	Cryptographic signature or watermark embedded at creation
Primary goal	Determine if a given asset is authentic or manipulated	Provide a verifiable record of origin and edit history
Strength	Works on any media, regardless of origin or tagging	Tamper-evident record that travels with the content
Weakness	Accuracy drops sharply in the wild; evadable by adversarial attacks	Metadata is stripped by platforms; watermarks can be removed

The practical implication is that both layers should be treated as signals feeding a larger verification decision rather than as stand-alone verdicts — the design principle developed further in Section 9.

7. The AI Governance Gap: From Principles to Practice

Governments and standards bodies have produced a wide array of AI governance frameworks converging on a common set of principles — transparency, accountability, fairness, and privacy — exemplified by the EU’s Assessment List for Trustworthy AI (ALTAI), which sets out seven key requirements, and by the NIST AI Risk Management Framework, which describes seven characteristics of trustworthy AI including validity, reliability, and security [26]. The persistent challenge is a “principle–practice gap”: organizations frequently adopt these principles on paper without operationalizing them, and one review of Fairness, Accountability, and Transparency in Engineering (FATE) practices found fewer than half of examined systems had robust accountability mechanisms in place.

The gap has several drivers: definitional disagreement over terms like “fairness” and “transparency” that resists standardized metrics; uneven institutional capacity, particularly for smaller organizations; a structural regulatory lag relative to the pace of capability growth; and a genuine tension between innovation and control that makes overly rigid governance counterproductive. Practical tools such as the CLeAR documentation framework and the ALTAI checklist help translate principles into concrete self-assessment steps, but they depend on honest engagement and are not independently verified — which is precisely why the framework proposed in Section 10 builds in mandatory third-party red-team audits rather than relying on self-assessment alone.

8. The Human Factor: Cognitive Offloading and Media Literacy

Technological defenses are ultimately mediated by human perception and behaviour, and two related deficits undermine them. The first is cognitive offloading: the well-documented tendency to rely on external tools for tasks once performed mentally, which can erode the underlying analytical skill over time. Generic critical-thinking instruction often fails because it does not account for how people actually interact with automated verification tools, and users faced with information overload naturally defer to an automated verdict rather than investigating further.

The second is a pervasive media and AI literacy deficit that affects even trained professionals. Newsrooms have had to rethink evidence-authentication workflows as deepfake technology advances, and journalists — who are expected to be the frontline verifiers of public information — are turning to imperfect AI tools that should serve only as a starting point for manual investigation. The SIFT method (Stop, Investigate the source, Find better coverage, Trace claims to the original context) remains a core skill for navigating this landscape. Compounding the problem, style and fluency — once reliable signals of authenticity — are losing their diagnostic value as AI-generated content becomes more convincing, a “transparency penalty” that makes it harder for any audience to gauge credibility from surface cues alone.

Human Factor	Implication for Defense
Cognitive offloading	Users become dependent on imperfect detection tools and skip deeper verification
Media/AI literacy deficit	Professionals and the public alike struggle to critically evaluate synthetic content
Confirmation bias	People accept and share synthetic media that matches their existing beliefs
Information overload	Fast-moving situations force superficial, error-prone snap judgments
Trust in authority/AI	Users defer to an automated verdict without probing its limitations

Mitigation requires designing systems that augment rather than replace human judgement. Explainable AI (XAI) that provides the reasoning behind a verdict — rather than a black-box label — helps build a discerning “AI sense” over time, while “implementation intentions” — specific, pre-committed plans linking a cue to an action, such as a policy to always verify a source’s credentials before acting on a request — help translate awareness into consistent verification behaviour.

9. Zero Trust as the Unifying Paradigm

Zero Trust Architecture (ZTA) offers the most compelling integrative framework for the disparate defenses discussed above. Grounded in “never trust, always verify,” ZTA eliminates the concept of a trusted network perimeter and treats every access request — human, device, or AI agent — as untrusted until it is rigorously authenticated and authorized, on the assumption that a breach is inevitable and the goal is to minimize its blast radius through continuous monitoring and least-privilege access [27].

ZTA’s real power is that it subsumes detection and provenance rather than treating them as isolated products. When a user attempts to send or receive a piece of media, a detection engine’s confidence score and a provenance credential’s validity both become attributes feeding a single authorization decision; a missing or tampered C2PA credential, for instance, can automatically escalate a request for human review rather than being ignored or treated as a definitive verdict either way.

The same model extends naturally to Agentic AI: every action an autonomous agent takes is continuously validated against behavioural baselines, so an agent attempting to access data or systems outside its designated scope triggers the same kind of alert as an anomalous human user, with its trust level and privileges adjusted dynamically based on observed behaviour rather than fixed at provisioning time.

ZTA Principle	Application to Synthetic Media & AI Threats
Verify explicitly	Scan all incoming media for deepfakes and check provenance credentials before granting access
Least privilege access	Restrict AI agents to only the data and APIs they need to limit damage from misalignment
Assume breach	Continuously monitor communications and AI-generated content for anomalous patterns
Secure data by sensitivity, not location	Encrypt and gate access based on verified identity, not network position
Micro-segmentation	Isolate AI development environments from production to contain a compromised model
Continuous monitoring	Use ML-based behavioural analysis to detect AI-driven attacks or synthetic-media misuse in real time

ZTA also addresses the governance and human-factor gaps discussed in Sections 7 and 8: its detailed access logs support the auditability that regulators like SEBI now require, and by performing verification automatically and transparently at the system level, it shifts the burden of catching a deepfake away from any single fallible reviewer and toward a consistent, system-wide baseline.

10. A Proposed Synthesis: The Trusted Digital Exchange Framework for Indian Enterprises

Synthesizing the preceding sections, this paper proposes an Indian-context adaptation of a Trusted Digital Exchange (TDE): a socio-technical framework built on four interlocking layers, designed to shift the operative question from an unattainable “is this real?” to a manageable, continuous assessment of probabilistic risk.

10.1 Layer One — Foundational Mindset (Zero Trust)

Every entity — employee, customer, vendor system, or AI agent — is treated as untrusted by default. This means migrating from perimeter-based defenses to identity-centric ones: strong multi-factor authentication for all users and systems, network segmentation to limit lateral movement, and continuous monitoring of every access request, forming the auditable foundation on which the remaining layers depend.

10.2 Layer Two — Verification Engine (Provenance + Detection)

All content created or distributed under enterprise auspices should carry a C2PA Content Credential where feasible, with invisible watermarking (e.g., SynthID-class technology) as a fallback where metadata persistence cannot be guaranteed. Every external media input entering a sensitive workflow — a video-KYC session, an executive video call authorizing a transfer — should pass through a multi-model detection engine. Neither signal is treated as final; both feed the next layer.

10.3 Layer Three — Intelligence Layer (Dynamic Trust Score with XAI)

Provenance status, detection confidence, source reputation, and transaction sensitivity are combined into a single probabilistic trust score rather than a binary verdict. Critically, the system must be explainable: a low score should come with a concrete, non-technical reason (for example, inconsistent facial micro-expressions or anomalous audio frequency patterns) so that a human reviewer can make an

informed final call rather than deferring blindly — directly addressing the cognitive-offloading risk identified in Section 8.

10.4 Layer Four — Governance Process

Governance is treated as a continuous cycle rather than a policy document: mandatory third-party red-team audits before any high-risk AI system is deployed, participatory review involving affected business units and, where relevant, external stakeholders, and a tested incident-response playbook for a discovered deepfake or AI-generated disinformation event, covering containment, notification, and remediation.

10.5 Mapping the TDE to the Indian Regulatory Context

This structure is not abstract; it operationalizes obligations Indian enterprises already face or will shortly face. The Verification and Intelligence layers give a regulated entity the audit trail SEBI’s December 2024 consultation paper requires when assigning liability for AI-tool outcomes, and the explicit disclosure language SEBI now expects from investment advisers using AI. The Foundational layer’s hardware-backed authentication and out-of-band verification directly counter the deepfake BEC and digital-arrest vectors in Section 4, while capture-provenance analytics at the Verification layer — checking device telemetry for virtual camera drivers or emulators — is the concrete control the RBI’s liveness-detection mandate requires against Video-KYC injection attacks. Finally, the Governance layer’s audit logs and documented processing rationale help satisfy the DPDP Act’s implicit transparency requirements around automated decision-making, even in the absence of an explicit statutory “right to explanation.”

10.6 Practical Enterprise Controls

At the operational level, the TDE is realized through specific, currently available controls:

- Out-of-band, multi-party authorization for any fund transfer above a defined threshold, verified over a pre-registered secondary channel rather than the channel the request arrived on.
- Confidential “safe words” or challenge-response phrases for executives and finance staff, as a low-tech barrier against real-time deepfake impersonation.
- Hardware security keys (FIDO2/WebAuthn) for privileged accounts, removing reliance on phishable digital tokens or SMS-based one-time passwords.

- Layered liveness detection combining physical presentation-attack checks (depth mapping, remote photoplethysmography) with capture-provenance analytics that inspect device telemetry for virtual camera drivers or emulator signatures.
- Communication-security platforms that model normal organizational communication graphs to flag anomalous executive impersonation even when language is flawless.
- Extended Detection and Response (XDR) tooling that identifies autonomous or polymorphic threats by behaviour — unauthorized network mapping, memory injection — rather than static signatures.
- Internal model firewalls that sit between users and enterprise large language models to screen for prompt injection, training-data poisoning, and unauthorized data disclosure.
- Formal mapping of internal AI governance to ISO/IEC 42001 and the NIST AI Risk Management Framework, ahead of binding domestic AI-specific regulation.

11. Strategic Conclusions and Recommendations

Two conclusions follow from the analysis above. First, no single fix — legal, technical, or educational — is sufficient on its own. India’s regulatory instruments are actively catching up: SEBI and the RBI are moving faster and more specifically than the IT Act or even the DPDP Act, but enterprises cannot wait for the legislative gaps in mens rea and algorithmic liability to close before acting. Second, the global literature on detection, provenance, governance, and human cognition converges on the same architectural answer that Indian regulators are independently arriving at through sector-specific mandates: continuous, Zero Trust–anchored verification that treats every signal — a biometric feed, a wire-transfer request, an AI agent’s action — as provisional until authenticated.

This paper's analysis translates into five concrete priorities:

Adopt out-of-band verification and hardware-backed authentication for every high-value financial transaction and executive communication channel.

Deploy layered liveness detection and capture-provenance analytics across all Video-KYC and onboarding workflows, rather than relying on presentation-attack detection alone.

Integrate internal model firewalls and XDR tooling to counter autonomous, agentic intrusion attempts rather than signature-based malware alone.

Map AI governance processes to ISO/IEC 42001 and the NIST AI RMF now, positioning the organization ahead of anticipated DPDP Rules and SEBI/RBI circulars rather than reacting to them.

Invest in recurring, scenario-based "AI sense" training for finance, compliance, and customer-facing staff, built around implementation-intention protocols rather than one-off awareness sessions.

References

- [1] Sectoral and functional AI adoption benchmarks, compiled from industry adoption surveys, 2025–2026.
- [2] Drishti Judiciary, “Digital Arrest: The Modern-Day Cyber Scam,” <https://drishtijudiciary.com/to-the-point/bharatiya-nyaya-sanhita-&-indian-penalcode/digital-arrest-the-modern-day-cyber-scam>
- [3] PMF IAS, “Digital Arrest Scams,” <https://www.pmfias.com/digital-arrest/>
- [4] National Human Rights Commission, India, press release on digital arrest scams, <https://nhrc.nic.in/media/press-release/>
- [5] RTI Wiki, “AI Voice Scam in India: Spot, Stop & Recover (2026),” <https://righttoinformation.wiki/ai-voice-scam-recovery>
- [6] Press Information Bureau, “AI-Enabled Cyber Crime Prevention and Digital Identity Protection,” <https://www.pib.gov.in/PressReleasePage.aspx?PRID=2298336>
- [7] Sarkaritel, “I4C Warns Of AI Deepfake Fraud Threat Targeting Financial [Institutions],” <https://www.sarkaritel.com/i4c-ai-deepfake-authentication-bypass-advisory/>
- [8] Signzy, “Liveness Detection in 2026: Active, Passive and Layered Approaches,” <https://www.signzy.com/blogs/liveness-detection-deepfake-injection-attacks>
- [9] Signzy, “Liveness Detection Bypass: How Deepfake Injection Attacks Defeat Verification,” <https://www.signzy.com/blogs/liveness-detection-bypass-deepfake-injection>
- [10] arXiv, “The Ethics of Autonomous AI Agents for Offensive Security,” <https://arxiv.org/html/2607.20255v1>
- [11] arXiv, “Inherent and Emergent Liability Issues in LLM-Based Agentic Systems,” <https://arxiv.org/html/2504.03255v1>
- [12] Finsec Law Advisors, “SEBI Advisory on AI-Driven Vulnerabilities,” <https://www.finseclaw.com/article/sebi-advisory-on-ai-driven-vulnerabilities>
- [13] Securities and Exchange Board of India, “Advisory on Emerging Advanced Artificial Intelligence Tools for Vulnerability Detection,” May 2026, <https://www.sebi.gov.in/legal/circulars/>
- [14] Securities and Exchange Board of India, Consultation Paper on “Assigning Responsibility for the Use of Artificial Intelligence Tools,” December 2024, https://www.sebi.gov.in/sebi_data/meetingfiles/dec-2024/
- [15] Univest, “AI Disclosure by Investment Advisers: What Clients Should Be Told,” <https://univest.in/blogs/ai-disclosure-investment-adviser>
- [16] TaxGuru, “SEBI and AI Investment Advice: India’s Next Compliance Challenge,” <https://taxguru.in/sebi/>

- [17] CA Parveen Sharma, “SEBI AI Surveillance: What It Means for Audit & Disclosure,” <https://caparveensharma.com/articles/>
- [18] IISPPR, “AI and Data Protection: Challenges in Automated Decision-Making,” <https://iisppr.org.in/ai-and-data-protection-challenges-in-automated-decision-making/>
- [19] Unified Chambers, “AI Compliance India — Algorithmic Accountability & DPDP,” <https://www.unifiedchambers.com/ai-compliance-india>
- [20] Matters.AI, “DPDP Act 2023 Explained, Rules, Rights, and Penalties,” <https://www.matters.ai/compliance/dpdp/dpdp-act-2023>
- [21] Coalition for Content Provenance and Authenticity (C2PA), Content Credentials white paper, <https://c2pa.org/>
- [22] World Privacy Forum, “Privacy, Identity and Trust in C2PA: A Technical Review,” <https://worldprivacyforum.org/posts/privacy-identity-and-trust-in-c2pa/>
- [23] TrueScreen, “What Is C2PA? The Standard, Its Metadata and Real Limits,” <https://truescreen.io/articles/c2pa-standard-history-limitations/>
- [24] Reality Defender, “Deepfake Detection,” <https://www.realitydefender.com/>
- [25] UNESCO, “Deepfakes and the Crisis of Knowing,” <https://www.unesco.org/en/articles/deepfakes-and-crisis-knowing>
- [26] National Institute of Standards and Technology, “AI Risk Management Framework,” <https://www.nist.gov/itl/ai-risk-management-framework>
- [27] Cybersecurity and Infrastructure Security Agency, “Zero Trust,” <https://www.cisa.gov/topics/cybersecurity-best-practices/zero-trust>
- [28] arXiv, “A Survey of Agentic AI and Cybersecurity: Challenges, Opportunities,” <https://arxiv.org/html/2601.05293v1>
- [29] Acer Innovation, “NIST AI RMF x ISO/IEC 42001 Mapping,” <https://www.acerinnovation.com/nist-ai-rmf-iso-iec-42001-mapping>
- [30] Adaptive Security, “AI Deepfake Trends 2025–2026: Threats, Detection & Defense,” <https://www.adaptivesecurity.com/blog/ai-deepfake-trends-the-complete-2025-2026-guide-to-statistics-threats-detection-and-defense-strategies>